European Commission

DPP Registry Self-Hosting Authentication Guide for Economic Operators

DG Grow Digital Solutions

Last published 2026-10-30 v1.0



Table of Contents

Chapter 1. Introduction 4
1.1 About this Guide 4
Purpose and audience 4
Scope and Coverage 4
1.2 What the EO Implements 4
1.3 What the EO Does Not Implement 5

Chapter 2. Authentication and Trust Model 6
2.1 Actors and Responsibilities 6
2.2 End-to-End Flow 6
2.3 Trust Boundaries 7
2.4 Anonymous and Authorized DPP Representations 7

Chapter 3. Prerequisites and Requestor Identifier Configuration 8
3.1 Prerequisites 8
3.2 Obtain the org-identifier from the DPP Registry UI 8
3.3 Configure the Requestor Authorization Policy 9

Chapter 4. Hosting and Endpoint Requirements 10
4.1 Externally Visible HTTPS Origin 10
4.2 UPI Resolution and the Protected Endpoint 10
4.3 HTTP Requirements 10
4.4 Recommended Endpoint Behaviour 11

Chapter 5. Configure Trust in the DPP Authentication Service 12
5.1 Environment Trust Anchors 12
5.2 Authorization Server Metadata 12
5.3 JWKS Caching and Signing-Key Rotation 12
5.4 Behaviour During a DPP Authentication Service Outage 13

Chapter 6. DPP Registry Access Token Profile 14
6.1 JWT Protected Header 14
6.2 JWT Claims Example 14
6.3 Claim Reference 14
6.4 The resource_requestor_identifiers Claim 15
6.5 Audience and Requestor Authorization Are Separate Controls 15

Chapter 7. Validate and Authorize Registry Requests 16
7.1 Required Validation Order 16
7.2 Requestor Match Rule 17
7.3 Dedicated-Origin Example 17
7.4 Shared Multi-Tenant Example 18

Chapter 8. HTTP Requests and Error Responses 19
8.1 Anonymous Request - Public Representation 19
8.2 Authorized Request - Public and Protected Representation 19
8.3 Invalid Token - 401 19
8.4 Insufficient Scope - 403 20
8.5 Requestor Mismatch - 403 20
8.6 Response Status Summary 20

Chapter 9. UPI Resolution and Redirect Behaviour 21
9.1 Maximum Redirects 21
9.2 Credentials During Resolution 21
9.3 Redirects After Authentication 21

Chapter 10. Operational and Security Recommendations 22
10.1 Transport and Endpoint Hardening 22
10.2 Token Handling 22
10.3 Logging and Monitoring 22
10.4 Availability and Fail-Closed Behaviour 22

Chapter 11. Error Handling and Troubleshooting 23

Chapter 12. Integration Validation Checklist 24
12.1 Minimum Conformance Test Matrix 24

Chapter 13. Reference Standards 26

Chapter 14. Glossary of Terms 27

Chapter 15. Helpdesk Contacts 28

Chapter 1. Introduction

1.1 About this Guide

Purpose and audience

This guide defines how an Economic Operator (EO), or a hosting provider operating on its behalf, protects an EO-hosted Digital Product Passport (DPP) endpoint that is retrieved by the DPP Registry. It translates the EO Self-Hosting Authentication architecture into vendor-neutral implementation guidance for the teams that build, operate and secure the EO Resource Server. This guide is intended for EO solution architects, API and platform engineers, DevOps and security teams, and hosting providers responsible for publishing protected DPP representations over HTTPS.

Scope and Coverage

This document covers:

- The DPP Registry-to-EO trust model and the responsibilities of each actor.
- The enrolment, Organisation verification and org-identifier prerequisites.
- The externally visible HTTPS origin used as the OAuth audience.
- Local JWT validation using DPP Authentication Service metadata and JWKS.
- The resource_requestor_identifiers claim and DPP-specific requestor authorization.
- UPI resolver and redirect behaviour, HTTP errors, key rotation, logging and go-live validation.

1.2 What the EO Implements

The EO exposes an OAuth 2.0 Resource Server. A GET request without an Authorization header returns the public DPP representation. When a valid DPP Registry JWT Bearer access token is present and the signed requestor identifier is authorized by the local policy for the requested DPP, the same endpoint returns the public plus protected representation. The Resource Server validates the token locally and never treats an invalid presented token as an anonymous request.

EO responsibility	Required outcome
Expose public and authorized representations	A GET without Authorization returns only the public DPP representation. A valid and authorized Registry token returns the public plus protected representation.
Trust the DPP Authentication Service	Validate access-token signatures only against the configured environment issuer and JWKS.
Validate the access-token profile	Require the expected token type, algorithm, issuer, principal type, lifetime, audience and scope.
Resolve expected requestor authorization locally	For every protected DPP, derive the expected requestor ORG_IDENTIFIER type and value from local authoritative policy.
Enforce resource_requestor_identifiers	Return protected content only when the signed requestor identifier type and value exactly equal the local expectation.
Return safe responses and logs	Do not disclose access tokens, protected DPP data or another tenant's requestor identifier.

1.3 What the EO Does Not Implement

The EO Resource Server is not the OAuth client in this flow and does not issue access tokens. The DPP Registry authenticates to the DPP Authentication Service before calling the EO API. Consequently, the EO does not manage Registry client credentials or reproduce the Registry-to-Authentication Service token exchange.

- Do not call the DPP Authentication Service /oauth2/token endpoint.
- Do not request or store a DPP Registry private or public client-authentication key.
- Do not validate the DPP Registry private_key_jwt client assertion.
- Do not call an introspection endpoint for every DPP request.
- Do not trust signing keys selected by jku, x5u or another URL from the incoming JWT.
- Do not require a refresh token, browser session, cookie or interactive OpenID Connect login.

> **KEY POINT**
> The EO trusts the DPP Authentication Service issuer and its access-token signing JWKS. The EO does not establish direct cryptographic trust in the Registry client key.

Chapter 2. Authentication and Trust Model

2.1 Actors and Responsibilities

Actor	Responsibility
DPP Registry	Resolves the UPI securely, consumes the public representation, obtains or reuses a resource-specific token and retrieves the public plus protected DPP as a DPP-owned SYSTEM client.
DPP Authentication Service	Authenticates Registry, applies resource and requestor-context policy, and signs the short-lived JWT access token.
EO Resource Server	Returns the public DPP anonymously; for a presented token, validates it locally and applies the local requestor-authorization policy before returning protected content.
DPP Registry UI	Displays the verified Organisation and its org-identifier, which the EO uses to configure the current requestor-authorization check.

2.2 End-to-End Flow

The DPP Registry first resolves the UPI by using GET without credentials. Redirects are followed under the Registry security policy until the final endpoint is reached. The final anonymous GET returns the public DPP representation, which Registry can begin processing immediately. Registry then obtains or reuses an access token whose audience is the final externally visible HTTPS origin and whose requestor context is derived from authoritative DPP data. Finally, Registry calls the same endpoint with the token; the EO Resource Server validates it locally, evaluates the signed requestor identifier against its local policy for the requested DPP and, when authorized, returns the public plus protected representation.

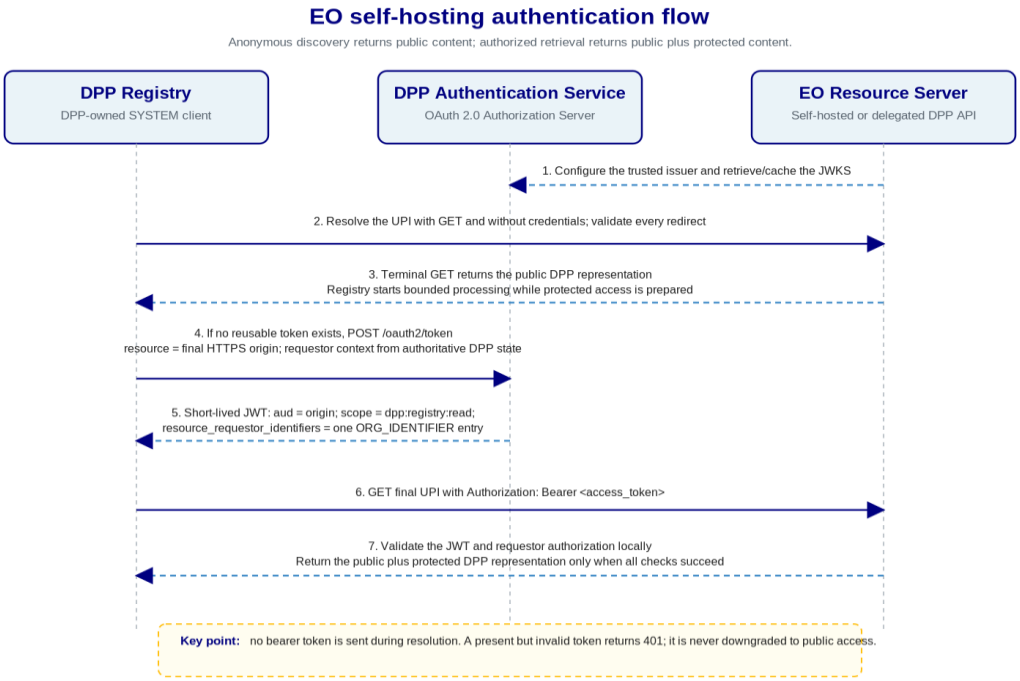


Figure 1 - EO self-hosting authentication flow

2.3 Trust Boundaries

The Registry client assertion and the access token are separate JWTs, signed by different keys for different purposes. The DPP Registry signs its client assertion with the Registry private client-authentication key when a new token is requested from the DPP Authentication Service. The DPP Authentication Service signs the resulting access token with its Authorization Server signing key. The EO validates only the access-token signature.

JWT	Presented to	Signed by	Validated by
Registry client assertion	DPP Authentication Service token endpoint	Registry private client key	DPP Authentication Service
DPP Registry access token	EO Resource Server	DPP Authentication Service access-token signing key	EO Resource Server using DPP JWKS

2.4 Anonymous and Authorized DPP Representations

The EO Resource Server MUST use the presence of the Authorization header to select the processing path. When the header is absent, it returns HTTP 200 with only the public DPP representation. When a valid token is present and the requestor is authorized, it returns HTTP 200 with the public plus protected representation. When the header is present but the token is malformed, untrusted, expired or otherwise invalid, it returns 401 and MUST NOT silently fall back to the public representation. A valid token with insufficient scope or a requestor-authorization failure returns 403 without private content.

Chapter 3. Prerequisites and Requestor Identifier Configuration

Complete the prerequisites in this chapter before configuring access-token validation. In particular, define a stable local authorization policy that identifies which verified Economic Operator requestor is permitted to retrieve protected content for each DPP. The requestor may be the DPP owner or another party entitled by that policy.

3.1 Prerequisites

- The Economic Operator has completed DPP enrolment.
- The Organisation status in the DPP Registry is VERIFIED.
- The EO can access the Organisation details area of the DPP Registry UI.
- The externally visible DPP endpoint uses HTTPS and has a stable public origin.
- The Resource Server can resolve the expected EO requestor identifier for every protected DPP from local authoritative policy.
- The implementation can validate JWTs using a configured issuer and remote JWKS.
- The implementation can enforce audience, scope and resource_requestor_identifiers checks before returning protected content.

3.2 Obtain the org-identifier from the DPP Registry UI

The current DPP access-token contract uses the verified Organisation's org-identifier as the requestor-authorization value. It identifies the Economic Operator on whose behalf Registry is making the request; it does not prove that the requestor owns the DPP. The org-identifier is available only after enrolment has completed successfully and the Organisation status is VERIFIED. It is not a secret, but it is security-relevant configuration and must be copied exactly as displayed.

In the DPP Registry UI, open Organisation > Verification. The value shown in the Organisation ID field is the verified Organisation's org-identifier. Copy the complete value exactly as displayed. Do not trim it, change its case, add a prefix or replace it with an internal tenant identifier.

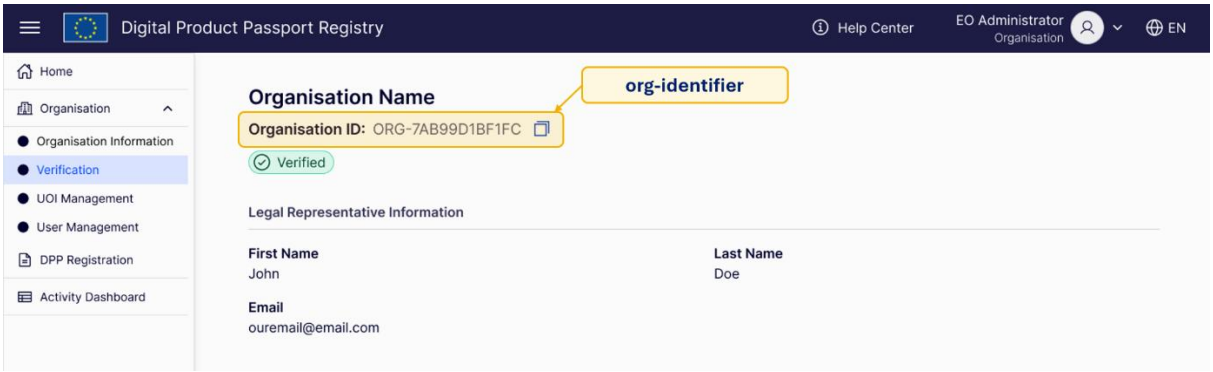


Figure 2 - DPP Registry UI: Organisation ID field containing the org-identifier

3.3 Configure the Requestor Authorization Policy

For each protected DPP, the Resource Server must determine the expected requestor identifier from local authoritative policy. The source may be tenant configuration, a DPP authorization record or another controlled entitlement model. The requestor may be the DPP owner or another entitled party. The expected identifier must never be taken from a query parameter, path value or request header supplied by the caller.

Hosting model	Recommended requestor-authorization policy
Dedicated EO origin	If only the verified Organisation is entitled, configure its org-identifier as the expected requestor for every protected DPP. Add another requestor only when the local policy explicitly grants that entitlement.
Shared multi-tenant origin	Maintain an authoritative per-DPP or per-tenant policy that resolves the expected requestor identifier independently from the shared host origin.

SECURITY
Never authorize protected DPP content from a requestor value supplied in the URL, query string or request headers. Resolve the expected requestor from local authoritative policy and compare it with the signed token claim.

Chapter 4. Hosting and Endpoint Requirements

4.1 Externally Visible HTTPS Origin

The OAuth resource and access-token audience are the canonical externally visible HTTPS origin of the final effective UPI target. The origin contains only the scheme, host and effective port. The default HTTPS port is omitted, while a non-default port is retained. Path, query and fragment components are excluded.

Effective UPI	Expected aud
https://hosting.example.com/acme/dpp/123	https://hosting.example.com
https://hosting.example.com/acme/dpp/123?format=json	https://hosting.example.com
https://hosting.example.com:443/dpp/123	https://hosting.example.com
https://hosting.example.com:8443/dpp/123	https://hosting.example.com:8443

When the API is deployed behind a reverse proxy, load balancer or service mesh, configure the expected audience from the externally visible origin. Do not derive an authorization decision from an internal host name or from untrusted Forwarded or X-Forwarded-* headers.

4.2 UPI Resolution and the Protected Endpoint

A UPI may initially address a public resolver. The Registry performs the complete resolution phase with GET and without credentials, so every resolver hop must be anonymously reachable. At the final endpoint, the anonymous GET returns the public DPP representation. Registry consumes that representation and may begin bounded processing while preparing authorized access. A subsequent GET with a valid and authorized token returns the public plus protected representation.

4.3 HTTP Requirements

Requirement	EO behaviour
Method	Support HTTPS GET for the final DPP URL.
Anonymous request	When the Authorization header is absent, return 200 with only the public DPP representation.
Authorized request	When the token is valid and the requestor is authorized, return 200 with the public plus protected DPP representation.
Invalid Authorization header	When the header is present but the token is invalid, return 401 and do not fall back to the public response.
Token transport	Accept exactly one Authorization header using the Bearer scheme. Reject tokens supplied in a query parameter or cookie.
Cookies and browser sessions	Do not require a browser session or use a cookie as a substitute for bearer-token validation.
Content type	Return the DPP representation using a media type supported by the applicable DPP profile: JSON, JSON-LD or XML. JSON format is the baseline.

Requirement	EO behaviour
Response caching	Return Vary: Authorization. Authorized responses must not be stored by shared caches.
Redirect after authentication	Avoid redirects after authentication. Registry does not assume that Authorization is forwarded.
Protected content on failure	Never include protected DPP attributes in a 401, 403 or diagnostic response.

4.4 Recommended Endpoint Behaviour

- Return the public plus protected representation directly after successful authorization.
- Use stable URLs and avoid cross-origin redirects after authentication.
- Return Vary: Authorization so caches distinguish anonymous and authorized representations. Apply Cache-Control appropriate to the representation; authorized responses must not be stored by shared caches.
- Apply request-size, response-size, timeout, rate-limit and abuse controls suitable for an Internet-facing API.
- Do not expose an alternative unprotected path to the same private representation.

Chapter 5. Configure Trust in the DPP Authentication Service

5.1 Environment Trust Anchors

Configure the issuer and JWKS independently for the Acceptance and Production environments, and never accept a token issued for the other environment. The EO Resource Server does not require the token endpoint for normal operation.

Environment	DPP Registry UI	Authorization Server issuer	JWKS endpoint
Acceptance	https://registry.acc.product-passport.ec.europa.eu/	https://auth.acc.product-passport.ec.europa.eu	https://auth.acc.product-passport.ec.europa.eu/oauth2/jwks
Production	https://registry.product-passport.ec.europa.eu/	https://auth.product-passport.ec.europa.eu	https://auth.product-passport.ec.europa.eu/oauth2/jwks

5.2 Authorization Server Metadata

The DPP Authentication Service publishes RFC 8414 Authorization Server metadata. Frameworks may use this metadata to discover jwks_uri. An EO may instead configure the issuer and JWKS URI explicitly, but both values must remain environment-specific and must not be derived from an incoming request. The Acceptance and Production metadata URLs are shown below.

Environment	Authorization Server metadata
Acceptance	https://auth.acc.product-passport.ec.europa.eu/.well-known/oauth-authorization-server
Production	https://auth.product-passport.ec.europa.eu/.well-known/oauth-authorization-server

5.3 JWKS Caching and Signing-Key Rotation

Fetch and cache the DPP Authentication Service JWKS; do not retrieve it for every DPP request. After enforcing the expected token type and algorithm, select the verification key by kid and validate the ES384 signature. During signing-key rotation, the JWKS may contain both the previous and the new public keys.

- Honor the HTTP caching headers returned by the JWKS endpoint.
- When an unknown kid is received, refresh the JWKS once and retry validation once.
- Reject the token if the kid remains unknown or the refreshed key does not validate the signature.
- Continue accepting an old signing key while it remains published and tokens signed with it can still be valid.
- Do not copy and pin a public key from this guide or from a support message.

SECURITY
Ignore jku, x5u or any other token-supplied key location. The only trusted access-token key source is the configured DPP Authentication Service JWKS for the selected environment.

5.4 Behaviour During a DPP Authentication Service Outage

Local JWT validation allows the EO API to validate already-issued tokens during a temporary DPP Authentication Service outage, provided that the required trusted signing key is already cached. If a token references an unknown key and the configured JWKS cannot be refreshed, the Resource Server must fail closed and return 401 for that presented token. Anonymous requests may still receive the public representation.

Chapter 6. DPP Registry Access Token Profile

6.1 JWT Protected Header

```
{
  "typ": "at+jwt",
  "alg": "ES384",
  "kid": "dpp-as-ec-p384-example"
}
```

6.2 JWT Claims Example

```
{
  "iss": "https://auth.product-passport.ec.europa.eu",
  "sub": "dpp-registry",
  "client_id": "dpp-registry-prod",
  "principal_type": "SYSTEM",
  "aud": "https://hosting.example.com",
  "scope": "dpp:registry:read",
  "resource_requestor_identifiers": [
    {
      "type": "ORG_IDENTIFIER",
      "value": "<verified-org-identifier>"
    }
  ],
  "iat": 1791431400,
  "exp": 1791431520,
  "jti": "at_01K..."
}
```

6.3 Claim Reference

Claim	EO validation or use
iss	Must exactly equal the configured DPP Authentication Service issuer for the target environment.
sub	Must be present and non-empty. Identifies the DPP Registry SYSTEM principal; it is not the Economic Operator requestor identifier.
client_id	Must be present and non-empty. Identifies the Registry OAuth client and may be used for diagnostics.
principal_type	Must be present with the exact value SYSTEM.
aud	Must exactly equal the EO Resource Server's configured externally visible HTTPS origin.
scope	Must exactly equal dpp:registry:read.
resource_requestor_identifiers	Must contain exactly one ORG_IDENTIFIER entry identifying the verified business requestor. See Section 6.4.
iat / exp	Both claims are required. Validate the active time window, bounded clock skew and a maximum lifetime of 120 seconds.
jti	Must be present and non-empty. It may support correlation, but the complete access token must never be logged.

6.4 The resource_requestor_identifiers Claim

The custom resource_requestor_identifiers claim carries the verified business requestor on whose behalf the DPP Registry is acting. The claim does not assert DPP ownership and does not replace the Registry SYSTEM principal. It allows a shared Resource Server to distinguish requests made for different Economic Operators even when the audience is the same HTTPS origin.

The current contract requires a typed array containing exactly one ORG_IDENTIFIER entry. Its value is the verified Organisation's org-identifier. The EO Resource Server resolves the expected requestor identifier from its local policy for the requested DPP and compares both the identifier type and value exactly.

```
"resource_requestor_identifiers": [
  {
    "type": "ORG_IDENTIFIER",
    "value": "<verified-org-identifier>"
  }
]
```

DPP plans to introduce UOI processing through a future version of this custom claim. Until the corresponding DPP contract and implementation guidance are published, EO implementations must continue to require ORG_IDENTIFIER and reject any unsupported identifier type.

6.5 Audience and Requestor Authorization Are Separate Controls

Audience validation prevents a token issued for one HTTPS origin from being replayed at another origin. It does not isolate requestors that share an origin. The resource_requestor_identifiers check and the Resource Server local policy provide that isolation. The Resource Server must enforce both controls; neither is a substitute for the other.

Chapter 7. Validate and Authorize Registry Requests

7.1 Required Validation Order

When the Authorization header is absent, return only the public DPP representation and do not enter the protected-token validation path. When the header is present, validate the token before relying on any claim value. Only after cryptographic, issuer, temporal, audience and scope validation succeeds may the Resource Server resolve the expected requestor identifier from local authoritative policy and apply the requestor comparison.

Step	Required check	Failure
1	Require HTTPS.	Reject request
2	If the Authorization header is absent, return only the public DPP representation and stop the protected-token path.	200 public
3	If the header is present, extract exactly one Bearer token.	401
4	Reject malformed or unreasonably large compact-JWT input before cryptographic processing.	401
5	Require alg=ES384 and typ=at+jwt; resolve kid only from the configured DPP Authentication Service JWKS and validate the signature.	401
6	Require the exact configured environment issuer.	401
7	Require non-empty sub, client_id and jti claims, and require principal_type=SYSTEM.	401
8	Validate iat and exp with bounded clock skew, require exp after iat and reject a lifetime greater than 120 seconds.	401
9	Require aud to exactly equal the configured externally visible HTTPS origin.	401
10	Require scope to exactly equal dpp:registry:read.	403
11	Require resource_requestor_identifiers to contain exactly one well-formed ORG_IDENTIFIER entry.	403
12	Resolve the expected requestor type and value from local authoritative policy for the requested DPP.	403
13	Require the signed requestor type and value to exactly equal the expected type and value.	403

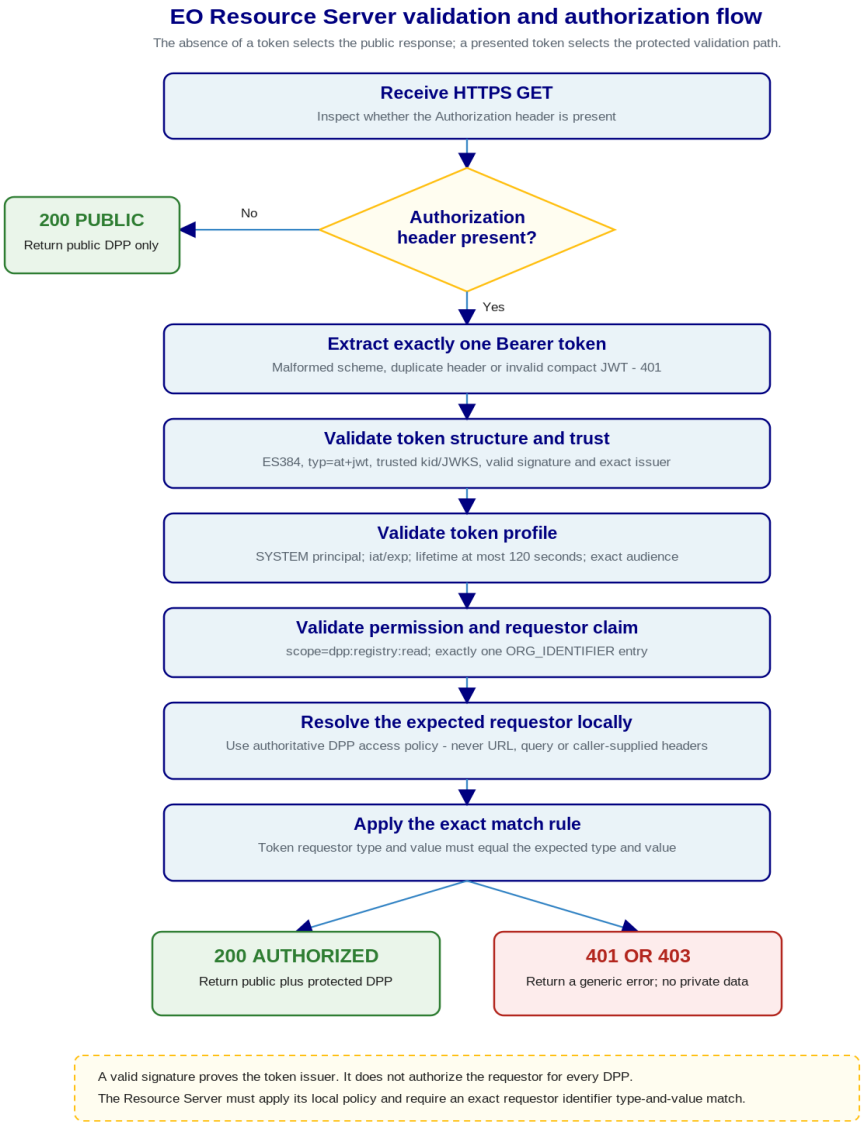


Figure 3 - EO Resource Server validation and requestor authorization flow

7.2 Requestor Match Rule

The following rule is normative for the current ORG_IDENTIFIER profile:

Authorization succeeds only when the type and value in the sole resource_requestor_identifiers entry exactly equal the expected type and value derived from the local access policy for the requested DPP. Do not normalize the value, compare only a suffix, ignore the identifier type or treat a host-level audience match as requestor authorization.

7.3 Dedicated-Origin Example

When the entire origin is dedicated to one verified Organisation and the local policy permits requests made on its behalf, configure that Organisation's org-identifier as the expected requestor for every protected DPP on the origin. Continue to enforce the requestor claim on each request so the implementation remains correct if the hosting or authorization model later changes.

7.4 Shared Multi-Tenant Example

A shared provider may host DPPs for ACME and CONTOSO at the same origin. Tokens for both requestors therefore carry the same aud value but different resource_requestor_identifiers. The provider must resolve the expected requestor from its local DPP access policy and return 403 when the signed type and value do not exactly match that expectation.

Request	Token requestor	Expected requestor	Result
/acme/dpp/123	ORG_IDENTIFIER / ACME	ORG_IDENTIFIER / ACME	Allow public plus protected content
/contoso/dpp/456	ORG_IDENTIFIER / ACME	ORG_IDENTIFIER / CONTOSO	Deny 403

SECURITY
A valid DPP Authentication Service signature proves who issued the access token. It does not prove that the signed requestor is authorized for every DPP. The local policy resolution and exact type-and-value comparison are mandatory.

Chapter 8. HTTP Requests and Error Responses

8.1 Anonymous Request - Public Representation

When the Authorization header is absent, the EO Resource Server returns HTTP 200 with the public DPP representation only. It must not include any protected attribute, and it must not require a browser session or cookie. If an Authorization header is present, the request is no longer anonymous: an invalid token returns 401 rather than falling back to the public representation.

Request state	Required API behaviour
Authorization header absent	200 OK with the public DPP representation only.
Valid token and authorized requestor	200 OK with the public plus protected DPP representation.
Authorization header present but token invalid	401 Unauthorized. Do not fall back to the public representation.
Valid token but insufficient scope or requestor not authorized	403 Forbidden without private DPP content or requestor disclosure.

8.2 Authorized Request - Public and Protected Representation

```
GET /acme/dpp/123 HTTP/1.1
Host: hosting.example.com
Authorization: Bearer <DPP_REGISTRY_ACCESS_TOKEN>
Accept: application/json
X-Correlation-Id: <correlation-id>
```

After token validation and requestor authorization have both succeeded, return the public plus protected DPP representation required by the Registry. Set Content-Type to the media type of the returned representation, include Vary: Authorization and prevent shared caches from storing the authorized response.

8.3 Invalid Token - 401

```
HTTP/1.1 401 Unauthorized
WWW-Authenticate: Bearer error="invalid_token"
Content-Type: application/problem+json

{
  "title": "Unauthorized",
  "status": 401,
  "detail": "The presented DPP Registry access token is invalid.",
  "correlationId": "<correlation-id>"
}
```

8.4 Insufficient Scope - 403

```
HTTP/1.1 403 Forbidden
WWW-Authenticate: Bearer error="insufficient_scope", scope="dpp:registry:read"
Content-Type: application/problem+json

{
  "title": "Forbidden",
  "status": 403,
  "detail": "The access token does not grant the required operation.",
  "correlationId": "<correlation-id>"
}
```

8.5 Requestor Mismatch - 403

Return a generic 403 response when the signed requestor context is not authorized for the requested DPP. The response must not reveal the expected requestor identifier, confirm whether another tenant exists or include any protected DPP attribute.

```
HTTP/1.1 403 Forbidden
Content-Type: application/problem+json

{
  "title": "Forbidden",
  "status": 403,
  "detail": "The requested resource is not authorized for this token.",
  "correlationId": "<correlation-id>"
}
```

8.6 Response Status Summary

Condition	Status
Authorization header absent	200 OK with public DPP content only
Valid token and requestor authorized	200 OK with public plus protected DPP content
Authorization header present but malformed JWT, unsupported token profile, unknown signing key, invalid signature, wrong issuer, invalid time window, excessive lifetime or wrong audience	401 Unauthorized
Valid token but missing required scope, malformed or unsupported requestor context, or requestor mismatch	403 Forbidden

Chapter 9. UPI Resolution and Redirect Behaviour

9.1 Maximum Redirects

The DPP Registry follows at most three redirects across the complete UPI resolution and retrieval process. The EO must therefore avoid any design that requires a fourth redirect. Redirect loops and Location values that violate the Registry security policy are rejected.

9.2 Credentials During Resolution

The Registry resolves the initial UPI and every resolver redirect by using GET without an Authorization header. Each resolver must therefore be publicly reachable. The final discovery GET returns the public DPP representation, which Registry consumes and may begin processing immediately while it obtains or reuses a token for the protected retrieval. The same endpoint is then requested again with authorization to obtain the public plus protected representation.

9.3 Redirects After Authentication

Do not assume that the Registry forwards a bearer token to a redirect target. When an authenticated endpoint returns 3xx, Registry removes the token, validates the new Location, recomputes the origin and requestor context, and obtains or reuses an appropriate token if processing continues. A cross-origin redirect always requires a token whose audience is the new origin.

> **RECOMMENDATION**
> Return the public representation from the terminal anonymous GET and return the public plus protected representation directly after successful authorization. Keep resolver redirects separate from the authorized retrieval endpoint and avoid redirects after a bearer token has been presented.

Chapter 10. Operational and Security Recommendations

10.1 Transport and Endpoint Hardening

- Support TLS 1.2 as the minimum protocol version and prefer TLS 1.3 where available.
- Use a publicly trusted certificate and strict hostname validation.
- Reject clear-text HTTP and do not downgrade HTTPS redirects to HTTP.
- Apply rate limiting, connection limits, request-header limits and bounded response generation.
- Keep private DPP retrieval isolated from public administrative or debugging endpoints.

10.2 Token Handling

- Treat the access token as a bearer credential until it expires.
- Never log the Authorization header or complete access token.
- Do not persist Registry access tokens as EO business data.
- Do not require or issue refresh tokens in the EO Resource Server.
- Do not make a synchronous introspection call for every request.
- Do not accept a token solely because its signature is valid.

10.3 Logging and Monitoring

Record enough information to diagnose interoperability failures without exposing credentials or private data. Recommended fields include the correlation identifier, token kid, configured issuer, expected audience, high-level validation result and requestor-authorization result. Never place access-token values, private DPP attributes or unbounded requestor identifiers in logs or metric labels.

10.4 Availability and Fail-Closed Behaviour

For a request that presents an Authorization header, the Resource Server must fail closed whenever it cannot validate trust, the token profile, audience, scope or requestor authorization. This rule does not change the anonymous path: a request without an Authorization header receives only the public representation.

Chapter 11. Error Handling and Troubleshooting

Symptom	Likely cause	Recommended check
401 - unknown kid	Signing-key rotation or stale JWKS cache	Refresh the configured DPP JWKS once and verify that the issuer and JWKS belong to the same environment.
401 - invalid token profile	Unexpected alg or typ, missing mandatory claim, or principal_type is not SYSTEM	Require alg=ES384, typ=at+jwt, the mandatory claims and principal_type=SYSTEM.
401 - invalid signature	Wrong issuer/JWKS, modified token or untrusted signing key	Use only the configured environment JWKS and reject token-supplied key URLs.
401 - wrong audience	Configured expected origin does not match the external UPI origin	Check scheme, host, effective port and reverse-proxy configuration.
401 - expired or excessive lifetime	Clock error, delayed request, invalid iat/exp or a lifetime greater than 120 seconds	Synchronize system time, apply only bounded skew and enforce the 120-second maximum.
403 - insufficient scope	Token is not a Registry retrieval token	Require scope to exactly equal dpp:registry:read.
403 - requestor mismatch	The signed requestor identifier does not match the type and value expected by the local DPP access policy.	Check the verified org-identifier and the local requestor-authorization policy for the requested DPP.
403 - malformed requestor claim	Missing entry, unsupported type, extra entries or invalid object shape.	Require exactly one ORG_IDENTIFIER object containing a non-empty value.
Repeated redirect failure	Protected endpoint redirects after authentication or the overall chain is too long	Return the final DPP directly and keep the complete redirect chain within three redirects.
JWKS unavailable	Network or DPP Authentication Service outage	Use a cached trusted key when available; otherwise fail closed and retry later.

SUPPORT
When raising a Helpdesk request, include the environment, UTC timestamp, correlation identifier, public endpoint URL and high-level failure stage. Never include an access token, Authorization header, private DPP content or private key.

Chapter 12. Integration Validation Checklist

Complete the following checks in the Acceptance environment before enabling protected DPP retrieval in Production. Repeat the environment-specific checks whenever the issuer, JWKS, public origin, requestor-authorization policy or security middleware changes.

- The Organisation enrolment is complete and its status is VERIFIED.
- The configured org-identifier exactly matches the value displayed for the verified Organisation in the DPP Registry UI.
- Every protected DPP has an authoritative local policy that resolves the expected requestor identifier.
- The configured issuer and JWKS belong to the same DPP environment.
- JWKS keys are cached and unknown-kid refresh is implemented.
- The Resource Server accepts only ES384 access tokens with typ=at+jwt, requires principal_type=SYSTEM and enforces a maximum 120-second lifetime.
- aud is compared exactly with the externally visible HTTPS origin.
- scope must exactly equal dpp:registry:read.
- resource_requestor_identifiers is validated as an array containing exactly one ORG_IDENTIFIER object.
- An ORG_IDENTIFIER whose type and value exactly match the local expectation allows the protected DPP request.
- A non-matching ORG_IDENTIFIER returns 403 without protected data or requestor disclosure.
- A token from another DPP environment is rejected.
- An expired or overlong token, unsupported token profile, wrong issuer, wrong audience and invalid signature return 401.
- The endpoint does not depend on introspection or the Registry public key.
- Authorization headers and access tokens are absent from logs.
- The redirect chain does not exceed three redirects; the terminal anonymous GET returns public content and the authorized endpoint returns public plus protected content directly.

12.1 Minimum Conformance Test Matrix

Test	Expected result
Authorization header absent	200 and only the public DPP representation is returned.
Valid token; correct profile, audience, scope and requestor match	200 and the public plus protected DPP representation is returned.
Authorization header present but token invalid	401; no fallback to the public representation.
Valid token; wrong requestor identifier	403 without protected content or the expected requestor identifier.
Valid token; wrong audience	401.
Valid token; scope is not exactly dpp:registry:read	403.
Expired token	401.
Token lifetime greater than 120 seconds	401.

Test	Expected result
principal_type absent or not SYSTEM	401.
Unknown kid after one trusted JWKS refresh	401.
Invalid ES384 signature	401.
Malformed resource_requestor_identifiers	403.
Production token sent to an Acceptance endpoint	401.

Use the minimum conformance test matrix above as a baseline for implementation and regression testing. It does not replace end-to-end testing with access tokens issued by the Acceptance environment.

Chapter 13. Reference Standards

Reference	Use in this guide
RFC 6750 - The OAuth 2.0 Authorization Framework: Bearer Token Usage	Authorization header and bearer-token error semantics.
RFC 7517 - JSON Web Key (JWK)	DPP Authentication Service public JWKS.
RFC 8414 - OAuth 2.0 Authorization Server Metadata	Issuer metadata and jwks_uri discovery.
RFC 8707 - Resource Indicators for OAuth 2.0	Registry requests a token for the final protected-resource origin.
RFC 9068 - JSON Web Token Profile for OAuth 2.0 Access Tokens	JWT access-token structure and Resource Server validation.
RFC 9700 - Best Current Practice for OAuth 2.0 Security	Current OAuth security recommendations.

Chapter 14. Glossary of Terms

Term	Meaning
DPP	Digital Product Passport.
EO	Economic Operator responsible for the DPP or its hosting arrangement.
UPI	Unique Product Identifier expressed as a URL and resolved by Registry.
Resource Server	The EO-hosted or delegated API that validates the DPP Registry access token and returns the protected DPP.
Authorization Server	The DPP Authentication Service acting as the OAuth 2.0 Authorization Server; it authenticates Registry and issues the JWT access token.
JWKS	JSON Web Key Set containing DPP Authentication Service public token-verification keys.
org-identifier	Identifier assigned to a verified DPP Organisation and displayed in the DPP Registry UI. It is the current requestor-authorization value carried in resource_requestor_identifiers.
UOI	Unique Operator Identifier. DPP plans to introduce UOI processing through a future version of resource_requestor_identifiers.
Canonical origin	The HTTPS scheme, host and effective port of the final UPI target, excluding path, query and fragment.
resource_requestor_identifiers	Typed access-token claim that identifies the verified Economic Operator requestor on whose behalf Registry acts. It does not prove DPP ownership.

Chapter 15. Helpdesk Contacts

Need help using the platform or diagnosing an integration issue? The DPP Helpdesk team is available to support you.

- Email: EC-HELPDESK-DPP@ec.europa.eu

Responses are provided Monday to Sunday, from 8 AM until 8 PM CET.

- Phone: +32 22960431

Available Monday to Sunday, from 8 AM until 8 PM CET.

- Include the DPP environment, UTC timestamp, correlation identifier and public endpoint URL.
- Describe the failing validation stage and HTTP status without attaching private DPP content.

> **SECURITY**
> Never include private keys, access tokens, Authorization headers, complete JWTs or private DPP content in a Helpdesk request.